EnterpriseOS

Business Requirements Document (BRD) + Software Requirements Specification (SRS)

Phase 1: Foundation, Organization Onboarding, Identity & Access Management

Document control	Value
Version	1.0 - Client review draft
Status	Proposed; all unconfirmed requirements are assumptions
Prepared for	Client / Business Sponsor
Project stack	React + TypeScript; Java Spring Boot; MySQL
Deployment model	Multi-tenant SaaS (proposed)
Date	11 November 2026
Approval	Pending client sign-off

Purpose: Collect the decisions and inputs required from the client, freeze a testable Phase 1 scope, and establish measurable acceptance criteria before development.

1. Executive Summary

EnterpriseOS is a multi-company enterprise operations platform. Phase 1 will deliver a secure foundation for company onboarding, account authentication, role-based access, organization setup, and a functioning administrative portal. Employee payroll, CRM, project tracking and other business modules are explicitly deferred.

Proposed outcome: A platform administrator can provision and administer company tenants; an organization administrator can configure their company, invite users, assign permissions and view an initial dashboard; authenticated members only access permitted resources belonging to their own organization.

2. Client Discovery - Information Required Before Kickoff

Category	Client input / decision needed
Business	Legal business name, industry, contact person, primary use cases, success criteria, number of companies.
Users	Expected active users at launch and year 1; admin types; any external contractors.
Deployment	Cloud/on-premise preference, hosting account owner, region, domain/subdomain strategy.
Identity	Email/password vs SSO, MFA requirement, invite-only vs self-registration, password policy.
Tenant model	Shared application with tenant isolation vs dedicated database per company; any regulated tenants.
Roles	Approved role names, permission matrix, maker-checker expectations, super-admin powers.
Company setup	Required company fields, departments, branches, branding, timezone, fiscal-year settings.
Email	Sender domain, SMTP/email provider access, approval for

	invitation/reset templates.
Compliance	Data residency, retention, deletion, legal/privacy requirements and audit duration.
Operations	Support hours, backup/restore expectations, availability objectives, incident contacts.
Branding	Logo, colors, typography, company name, legal footer and accessibility needs.
Sign-off	Budget, milestone approvers, review turnaround, change-request process.

3. Stakeholders and Roles

Actor	Phase 1 responsibility / access
Client sponsor	Approves scope, budget, launch criteria and change requests.
Client product owner	Confirms workflows, screens, validation rules and acceptance tests.
Platform Super Admin	Creates/suspends tenants, views platform-level tenant metadata; no routine access to tenant business records.
Organization Owner/Admin	Updates organization profile, manages invitations, users, roles and organization settings.
Manager / Member	Signs in and accesses only the pages/actions authorized for that role.
Development / QA / DevOps	Builds, tests, deploys and supports the approved Phase 1 baseline.

4. Phase 1 Functional Requirements

All IDs below are proposed for traceability. Priority P0 = mandatory; P1 = desirable only if explicitly approved.

ID	Requirement	Priority
FR-01	Platform admin signs in to a separate protected administration area.	P0
FR-02	Platform admin can create and activate a company tenant with unique slug.	P0
FR-03	Platform admin can suspend/reactivate a tenant; suspended users are blocked.	P0
FR-04	Organization admin can update legal/display name, email, address, timezone and logo.	P0
FR-05	Invite user by email, accept expiring single-use invite, and activate account.	P0
FR-06	Email/password login, logout, refresh/session management and password reset.	P0
FR-07	Organization admin can list/search/filter users, deactivate and reactivate them.	P0
FR-08	Manage predefined roles with documented permission mapping.	P0
FR-09	Enforce authorization on every	P0

	protected API; deny cross-tenant access.	
FR-10	Maintain audit records for login, invites, user/role changes and tenant status.	P0
FR-11	Basic dashboard: tenant profile, active users, pending invites and recent activities.	P0
FR-12	Form validation, error states, pagination and responsive layouts.	P0
FR-13	Configurable custom roles/permission builder.	P1
FR-14	Mandatory MFA or external SSO.	P1

5. Detailed Business Rules

- One user identity may belong to one or more tenants only if client explicitly approves multi-membership; default proposal is one tenant per user membership context.
- Every tenant-owned row must carry a tenant/company identifier; APIs derive tenant context from verified membership, never from an arbitrary client-supplied identifier alone.
- An organization may have more than one administrator; the final active owner/admin cannot deactivate their own last administrator privilege.
- Invitation tokens must expire, be single-use, and be stored as secure hashes; invitation lifetime proposed at 48 hours, pending client approval.
- Inactive accounts and suspended tenants must be rejected by the backend even when a valid older token exists.
- User email uniqueness and its scope (global vs within organization) must be confirmed by client before schema finalization.
- Platform support access to a company must be explicitly controlled and audited; no silent cross-tenant impersonation.
- All business-critical writes occur in database transactions; duplicate requests should not create multiple accounts or tenants.

6. Pages and User Journeys

Application area	Required screen / flow
Public	Sign in, forgot password, reset password, accept invite, error/access denied.
Platform Admin	Tenant list, create tenant, tenant detail/status, platform activity overview.
Company Admin	Dashboard, organization profile/settings, user directory, invitation flow, role display, audit history.
Member	Dashboard shell, personal profile, change password, authorized navigation.
Common	Loading states, empty states, confirmation dialogs, 403/404, session expiry.

Core journey A: Platform admin creates tenant -> organization owner receives activation invite -> owner sets password -> owner signs in -> completes company profile -> invites employees -> assigned roles govern portal access.

Core journey B: Organization admin removes user access -> backend invalidates or rejects subsequent protected access -> change is recorded in audit history.

7. Data Model - Proposed MySQL Entities

Entity	Key fields / notes
tenants	id, name, slug, status, created_at; unique slug
users	id, name, email, password_hash, status, last_login_at
tenant_memberships	tenant_id, user_id, status; supports explicit context/uniqueness
roles	id, tenant_id nullable for system roles, name, is_system
permissions	id, code, module, description
role_permissions	role_id, permission_id
membership_roles	membership_id, role_id
invitations	id, tenant_id, email, token_hash, expires_at, accepted_at, invited_by
password_reset_tokens	id, user_id, token_hash, expires_at, used_at
audit_events	id, tenant_id, actor_id, action, entity_type, entity_id, metadata, created_at
organization_profiles	tenant_id, legal_name, email, phone, address, timezone, logo_key
sessions / refresh_tokens	token/session identifier hash, user_id, expiry, revocation metadata

Database rules: InnoDB foreign keys, unique constraints, indexing by tenant_id and search keys, migration scripts (Flyway or Liquibase), UTC timestamps, soft-deletion where justified. Exact ERD and attribute types are part of design approval.

8. API Contract - Illustrative Endpoints

Method	Endpoint	Scope
POST	/api/v1/auth/login	Public
POST	/api/v1/auth/logout	Authenticated
POST	/api/v1/auth/forgot-password	Public
POST	/api/v1/auth/reset-password	Public
GET	/api/v1/me	Authenticated
GET	/api/v1/platform/tenants	Platform Admin
POST	/api/v1/platform/tenants	Platform Admin
PATCH	/api/v1/platform/tenants/{id}/status	Platform Admin
GET	/api/v1/org/profile	Tenant member
PUT	/api/v1/org/profile	Organization Admin
GET	/api/v1/org/users	Authorized tenant user
POST	/api/v1/org/invitations	Organization Admin
POST	/api/v1/invitations/accept	Invite recipient
PATCH	/api/v1/org/users/{id}/status	Organization Admin
GET	/api/v1/org/audit-events	Auditor/Admin

API standards: documented request/response schemas, meaningful HTTP status codes, field validation, pagination, filtering, stable error codes, request tracing, OpenAPI documentation; versioned /api/v1 namespace.

9. Non-Functional Requirements and Security

Area	Proposed requirement / decision
Security	TLS in transit, salted password hashing (Argon2id or BCrypt), secure cookies or controlled token storage, Spring Security authorization, CSRF protection as relevant.
Tenant isolation	Server-side tenant resolution; service/repository enforcement; automated negative cross-tenant tests.
Performance	Initial target: p95 API responses <= 500 ms for ordinary reads under agreed test load; client to approve actual workload.
Availability	Target and hosting SLA to be confirmed; no invented uptime guarantee.
Accessibility	Keyboard usable forms and semantic labels; target WCAG 2.2 AA subject to client agreement.
Privacy	Data minimization, retention configuration, logging without passwords/tokens/secret fields.
Reliability	Daily encrypted backups proposed; restore test required before release; RPO/RTO to be approved.
Observability	Health checks, structured logs, error monitoring, operational alerts.
Compatibility	Current Chrome, Edge, Firefox; responsive tablet/mobile web.
Engineering quality	Unit, integration, security and end-to-end tests; CI checks and code review.

10. Delivery Architecture and Environments

Frontend: React + TypeScript SPA with routing, reusable form components, authorization-aware navigation and typed API client. Backend: Java Spring Boot modular monolith with security, tenant, user, role, invitation, organization, audit and notification modules. Database: MySQL 8.4 LTS. Email: provider/SMTP selected by client. Infrastructure: Docker-based local setup, staging and production environments, HTTPS reverse proxy, centralized secrets and CI/CD. External providers and hosting costs are excluded unless separately agreed.

Recommended boundaries: Controllers -> application services -> domain rules -> repositories; DTO/request validation; transactional services; tests per module. No microservices, RabbitMQ or Kubernetes required for Phase 1.

11. Scope Boundaries

Included in Phase 1	Not included in Phase 1
Tenant provisioning & organization profile	HRMS, biometric attendance, leave approvals
Login, password reset, user invitations	Payroll, salary slips, tax calculations
Predefined roles, authorization and audit	CRM, leads, invoices, accounting
Admin dashboard and user directory	Inventory, procurement and asset tracking
Base architecture, API docs, tests, deployment	Project tasks, sprints, timesheets
Responsive MVP interface	Custom workflow designer, mobile apps, AI modules

Staging UAT and production handover	External SSO/MFA unless added by change request

12. Deliverables and Acceptance Criteria

Deliverable	Acceptance / proof
Requirements baseline	Client-approved BRD/SRS, role-permission matrix, wireframes and ERD.
Working source code	Version-controlled React app, Spring Boot API, migrations, env templates.
Tenant lifecycle	Create/suspend/reactivate tenant demonstrated with test records.
Identity flows	Login/reset/invite acceptance and denied access tested end to end.
Isolation controls	Automated tests demonstrate tenant A cannot read/update tenant B.
RBAC	Permission tests for admin, manager/member and unauthenticated users.
UX	Approved pages usable on desktop/mobile; agreed validation/error flows.
Quality	CI pipeline green; critical/high known security issues resolved or formally waived.
Operations	Staging/prod deployment guide, backup/restore walkthrough, runbook.
Handover	API docs, setup guide, release notes, known limitations and UAT sign-off.

13. UAT Test Scenarios

- UAT-01: Super admin provisions a valid company; duplicate slug is rejected.
- UAT-02: Company owner accepts an unexpired invite and signs in successfully.
- UAT-03: Expired or reused invitation links fail safely.
- UAT-04: Member cannot reach platform admin endpoint (403).
- UAT-05: Tenant A account cannot retrieve tenant B company profile or users (403/404).
- UAT-06: Deactivated account or suspended organization cannot access protected endpoints.
- UAT-07: Password-reset email does not disclose account existence; token expires/used once.
- UAT-08: Role change and user activation are recorded with correct actor and timestamp.
- UAT-09: Forms work on approved mobile/desktop browsers.
- UAT-10: Backup restore is demonstrated using a non-production environment.

14. Project Plan, Dependencies and Change Control

Stage	Work package	Exit gate
Discovery	Workshops, field definitions, workflows, role matrix	Requirements approved
Design	Wireframes, data model, API contracts, threat model	Design sign-off
Build A	Base repo, CI, schema, tenant context, authentication	Core integration tests pass
Build B	Org management, invitations, RBAC,	Feature demonstrations accepted

	dashboards, audit	
Verify	Security, regression, load baseline, UAT and restore test	UAT defects resolved
Release	Production deployment, documentation, training and handover	Client release approval

Timeline and price: intentionally TBD until user counts, SSO/MFA, hosting constraints, UI approval, compliance scope and staffing are confirmed. Any enhancement beyond the signed scope requires a change request stating cost, effort and impact before implementation.

Client dependencies: branding assets, approved email sender, hosting/domain access, designated reviewer, test users, legal/privacy text and timely UAT feedback. Delay in dependencies may move milestones.

15. Risks, Assumptions and Open Questions

Item	Treatment / decision owner
Assumption: shared multi-tenant deployment	Client confirms isolation/compliance requirement before design freeze.
Authentication policy unclear	Client approves MFA/SSO, reset rules, token/session policy.
Role matrix not finalized	Product owner signs a permission spreadsheet.
Email deliverability	Client supplies verified sender domain/provider and tests delivery.
Data privacy & retention	Client/legal approves data residency, deletion and retention policies.
Performance unknown	Agree concurrent users, sample data volumes and measurable SLAs.
Admin visibility across companies	Document and test support-access limitations explicitly.
Feature expansion during build	Apply documented change control and re-baseline milestones.

16. Client Requirements Questionnaire - Fill Before Sign-off

1. Client organization / project sponsor / decision maker: _____
2. Expected organizations and users (launch / year 1): _____
3. Registration: invite-only / public company sign-up / admin provisioned: _____
4. Authentication: password / mandatory MFA / SSO (specify provider): _____
5. User membership across multiple companies allowed? Yes / No: _____
6. Roles and approved permission matrix attached? Yes / No: _____
7. Hosting provider, region, domain and email sender: _____
8. Backup, audit retention, compliance requirements: _____
9. Branding, screen references, accessibility requirements: _____
10. UAT owner, acceptance process, milestones and budget: _____

17. Approval & Sign-off

By signing, stakeholders approve Phase 1 requirements, inclusions/exclusions and acceptance criteria as the baseline. Approval of this document is not a separate commercial contract, warranty or security certification.

Role	Name / signature	Date
Client Sponsor	_____	_____
Client Product Owner	_____	_____
Delivery Lead	_____	_____

End of document - v1.0 - Client review draft.